EGIS-SOC: Evidence-grounded Incident Summarization for SOC Analysts

KẾ HOẠCH NGHIÊN CỨU VÀ TRIỂN KHAI TRONG 8 TUẦN

Tên tiếng Anh mở rộng: *An Evidence-Verified and Omission-Aware Framework for Security Incident Summarization*

Lĩnh vực: Machine Learning for Cybersecurity · SOC · Incident Summarization · Trustworthy LLM

Thời gian thực hiện: 12/10/2026–06/12/2026

Phiên bản tài liệu: 1.0 · 09/10/2026

Trạng thái: Kế hoạch nghiên cứu (các chỉ tiêu và kết quả dự kiến chưa phải kết quả thực nghiệm)

Tóm tắt điều hành. EGIS-SOC là hệ thống hỗ trợ SOC analyst tổng hợp incident từ alert và log, sinh báo cáo kèm liên kết tới bằng chứng gốc, tự động kiểm chứng các nhận định (*claims*) và phát hiện những sự kiện quan trọng bị bỏ sót. Trọng tâm nghiên cứu là **(1) hybrid rule-based + ML evidence verification**, **(2) omission-aware controlled repair** và **(3) cross-environment generalization**. Hệ thống sử dụng retrieval + LLM để tạo bản nháp, nhưng không coi citation tồn tại là bằng chứng về độ đúng. Các kết quả cuối cùng phải được xác nhận trên bộ dữ liệu đã chú giải thủ công, đối chiếu baseline và kiểm nghiệm trên môi trường chưa xuất hiện khi training.

1. Bối cảnh, vấn đề và mục tiêu

1.1. Bối cảnh

SOC analysts phải tổng hợp thông tin từ SIEM alerts, Windows Event Logs, Sysmon, firewall, IDS/IPS và nhiều nguồn khác để viết một báo cáo incident nhất quán. LLM có thể tạo bản tóm tắt nhanh, nhưng có thể **hallucinate** (tự suy luận hành động không được chứng minh), **misattribute evidence** (dẫn chứng sai đối tượng, sai thời gian), hoặc **omit critical facts** (bỏ sót một mắt xích quan trọng).

Kramer và cộng sự (SOUPS 2025) nghiên cứu 18 analysts và 50 incidents thực tế; trong thiết lập nghiên cứu của họ, bản tóm tắt do LLM tạo bỏ sót chi tiết quan trọng trong 35% trường hợp và có factual inaccuracies trong 42% trường hợp. Đây là **kết quả của nghiên cứu nguồn**, không phải số liệu kỳ vọng của EGIS-SOC [R1]. Các công trình Cognitive SOC (IEEE BigData 2025), Zhang et al. (2026) và Cadet et al. (2026) đã đề cập evidence-backed narratives, verifiable generation hoặc retrieval-augmented incident analysis [R3–R5]. Do đó, riêng việc thêm RAG/citations không đủ để tuyên bố có tính mới.

1.2. Phát biểu bài toán

Đầu vào là **incident bundle** đã được xác định ranh giới: alert(s), log/evidence liên quan, thời gian, entities và incident metadata. Đầu ra là một **structured incident summary** gồm mô tả diễn biến, facts, findings, uncertainty và citation tới evidence IDs. Mỗi factual claim cần được kiểm chứng và các critical facts cần được đối chiếu về độ bao phủ.

EGIS-SOC **không** giải quyết toàn bộ bài toán phát hiện incident từ raw logs hoặc tự động thực hiện remediation. Analyst quyết định bản báo cáo cuối cùng.

1.3. Mục tiêu có thể nghiệm thu

1. Xây dựng pipeline từ Splunk/JSONL incident evidence → retrieval → LLM draft → claim verification → omission checking → controlled repair → analyst review.
2. Xây dựng tập claim–evidence có nhãn **Supported / Contradicted / Insufficient**, cùng tập **gold critical facts** cho các incidents.
3. So sánh **rule-only**, **ML-only** và **hybrid**; kiểm chứng các giả thuyết RQ1–RQ3.
4. Đo factuality, citation support, omission, latency, peak RAM, chi phí inference và robustness trong giới hạn thiết bị 4–12 GB RAM.
5. Bàn giao code, experiment scripts, dataset specification, báo cáo nghiên cứu và demo kiểm tra liên kết bằng chứng gốc.

1.4. Phạm vi và ngoài phạm vi

Trong phạm vi	Ngoài phạm vi giai đoạn 8 tuần
Incident đã được triage hoặc gom nhóm từ alert	Phát hiện toàn bộ incident end-to-end từ log stream
Evidence retrieval và claim-level verification	Khẳng định attribution/attack chain nếu không đủ evidence
Structured summary có citation	Autonomous SOC/agent tự hành động
Critical-fact omission checking và controlled repair	Huấn luyện foundation LLM từ đầu
OOD evaluation và analyst review	Production deployment/HA quy mô lớn
Tích hợp Splunk ở mức đọc có giới hạn	Điều phối full SOAR response

2. Research gap, đóng góp và Research Questions

2.1. Research gap và tính mới có điều kiện

Các nghiên cứu trước đã chứng minh nhu cầu LLM-assisted incident response, hệ thống trích dẫn và RAG. Khoảng trống được EGIS-SOC **đề xuất kiểm nghiệm**, không mặc định là khoảng trống chưa từng có nghiên cứu xử lý:

- **Support không đồng nghĩa với citation.** Evidence ID hợp lệ có thể dẫn tới một event không chứng minh toàn bộ claim; cần kết hợp tính đúng của thuộc tính SOC với entailment theo ngữ nghĩa.
- **Faithfulness khác coverage.** Chỉ loại bỏ claim sai có thể làm summary thiếu thông tin quan trọng; omission checking phải tăng coverage mà không tạo thêm suy luận thiếu cơ sở.
- **Domain shift.** Verifier dễ học shortcut từ log format, IP, hostname hoặc incident templates; cần thử nghiệm trên nguồn telemetry độc lập, tránh chỉ thay tên entities rồi gọi là unseen environment.

Contribution C1 — SOC-specific Hybrid Evidence Verification. Kết hợp deterministic validation (evidence ID, entity, temporal constraints, event semantics) với pretrained/fine-tuned NLI classifier, có trạng thái abstention và cơ chế audit quyết định.

Contribution C2 — Omission-aware Summarization. So khớp summary với critical-fact inventory độc lập, bổ sung fact còn thiếu bằng evidence gốc, giới hạn số vòng repair và re-verify mọi claim được thêm.

Contribution C3 — Cross-Environment Robustness Evaluation. Đánh giá shift về schema, telemetry, noise và environment; tách robustness đối với biến đổi biểu diễn khỏi generalization sang incident families chưa thấy.

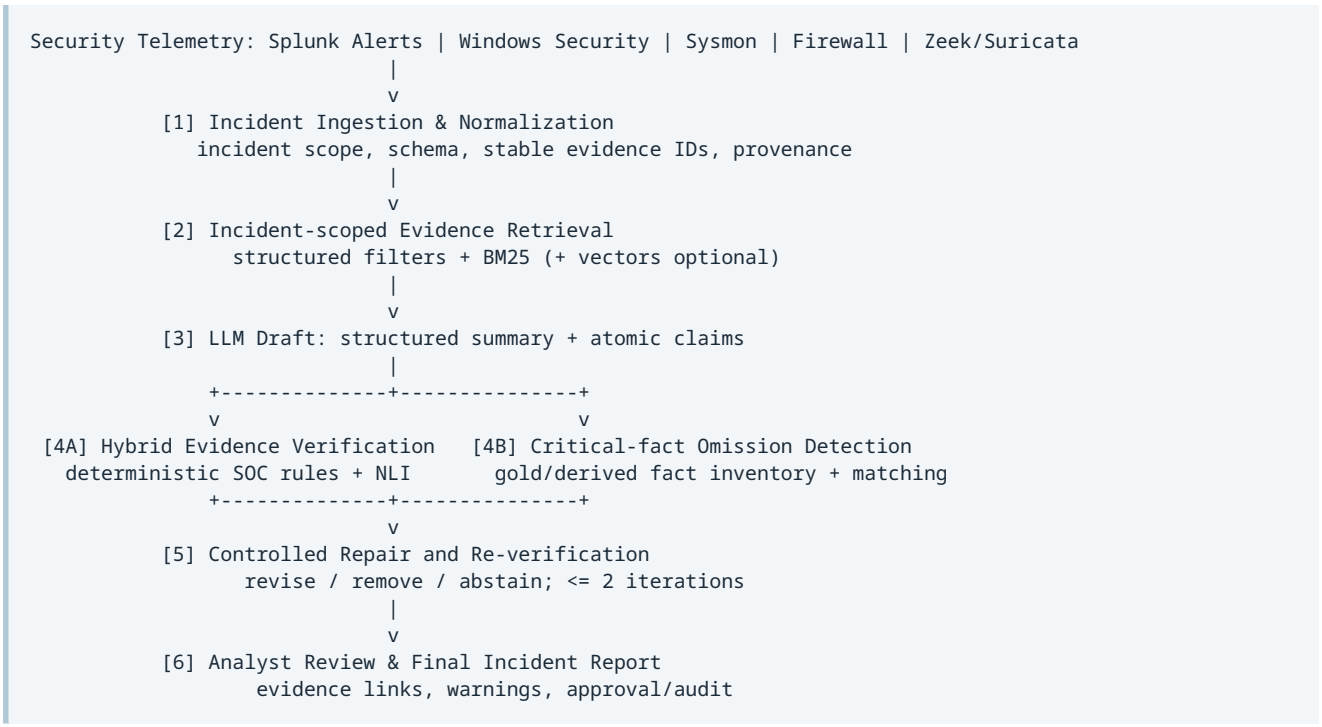
2.2. Research Questions và giả thuyết

RQ	Câu hỏi nghiên cứu	Giả thuyết cần kiểm chứng
RQ1	*Does hybrid rule-based and ML-based evidence verification improve claim-level factual correctness compared with ML-only verification?*	Hybrid tăng Macro-F1/Supported-class Precision và giảm false-support errors so với NLI-only trên cùng evidence.
RQ2	*Can omission-aware checking improve critical-fact coverage without materially increasing unsupported claims?*	S3 tăng Critical Fact Recall so với S2; mức tăng tuyệt đối UCR nhỏ hơn margin quy định trước (đề xuất 3 điểm %).
RQ3	*How robust is evidence verification under cross-environment shifts in security telemetry?*	Hybrid có suy giảm Macro-F1/Supported Precision nhỏ hơn NLI-only khi chuyển sang environment chưa được training.
RQ4 (phụ)	*What are the resource and human-review costs of the proposed system?*	Đo, không mặc định hứa hẹn giảm thời gian analyst hay chi phí.

Nguyên tắc nghiên cứu: đặt baseline, split, metric, ngưỡng và hypotheses **trước** khi nhìn vào kết quả test; sửa ngưỡng sau khi xem test được coi là exploratory, phải công bố rõ.

3. End-to-end architecture và luồng xử lý

3.1. Sơ đồ logic



3.2. Giao diện dữ liệu giữa các stage

Stage	Input	Output	Invariant
Ingestion	Search results/JSONL	Canonical events + evidence IDs	Raw log bất biến, có provenance
Retrieval	Incident ID + query/context	Top-k evidence IDs + passages	Không trả evidence thuộc incident khác
Generation	Retrieved evidence	Structured draft + atomic claims	Mỗi claim có IDs hoặc `uncited`
Verification	Claim + cited evidence	3-class verdict, score, rule trace	Không kết luận Supported chỉ vì ID tồn tại
Omission	Summary + fact inventory	Uncovered critical fact IDs	Facts phải có evidence/ support status
Repair	Failed claims + uncovered facts	Revised claims, citations	Giới hạn vòng lặp; không tự chế evidence
Review	Verified report + audit trail	Analyst-approved version	Không sửa/xóa raw evidence

3.3. Worked example (minh họa giả lập, không phải dữ liệu thực nghiệm)

```
E001 10:03:12 Security 4625 host=WS01 user=admin src=10.10.20.50 result=failed
E002 10:03:29 Security 4625 host=WS01 user=admin src=10.10.20.50 result=failed
E003 10:04:01 Security 4624 host=WS01 user=admin src=10.10.20.50 result=success
E004 10:06:18 Sysmon 1     host=WS01 image=powershell.exe cmd="Get-Process"
```

LLM draft chưa đạt: “The attacker brute-forced the administrator account and executed a malicious PowerShell payload. [E001–E004]”

Các event cho thấy hai failed logons, một successful logon và một lần chạy PowerShell, **không** chứng minh chắc chắn brute force thành công hoặc malicious payload. Omission checker đồng thời phát hiện summary thiếu địa chỉ nguồn và timeline.

Bản đúng hơn: “Two failed logon attempts for the admin account on WS01 from 10.10.20.50 were recorded between 10:03:12 and 10:03:29 [E001, E002]. A successful logon followed at 10:04:01 [E003]. PowerShell later executed `Get-Process` on WS01 [E004]. The available evidence does not establish brute-force compromise or malicious PowerShell activity.”

4. Thiết kế ML evidence verification

4.1. Bài toán supervised learning

Mỗi mẫu là `(claim, evidence set)` và một nhãn:

- **Supported (S):** bộ evidence đủ hỗ trợ mọi phần mang tính sự kiện của claim.
- **Contradicted (C):** evidence chứa thông tin đối nghịch trực tiếp; ví dụ cùng event nhưng process name khác.
- **Insufficient (I):** evidence chưa đủ để khẳng định hoặc bác bỏ claim; **absence of evidence ≠ contradiction**.

Bài toán chính là **three-class natural language inference / claim-evidence classification**. Ở mức baseline, có thể huấn luyện TF-IDF + Logistic Regression; phương pháp chuyên sâu dùng pretrained NLI model với đầu vào được chuẩn hóa từ log. `Insufficient` không thể bị ép thành `Contradicted`.

4.2. Input/feature design

Nguồn canonical fields: `event_time_utc`, `host`, `user`, `source_ip`, `dest_ip`, `event_provider`, `event_code`, `process_name`, `command_line`, `logon_type`, `outcome`, `raw_message` và `evidence_id`.

Derived features: `same_host`, `same_user`, `same_source_ip`, `time_delta_seconds`, `event_order_consistent`, `process_name_match`, `has_network_connection`, `citation_valid`, `evidence_count`, `telemetry_type`, `missing_fields_mask`.

Đối với cross-environment, không để classifier phụ thuộc vào **raw IP/hostname tokens** để dự đoán incident outcome. Các giá trị gốc vẫn phải giữ trong evidence store để audit. Nếu IP có ý nghĩa (private/public, same subnet, internal/external), chuyển thành tính chất ngữ nghĩa; không xóa toàn bộ IP khỏi quá trình kiểm chứng.

4.3. Model candidates và thứ tự triển khai

Thành phần	Phương án	Ghi chú
ML baseline	TF-IDF + Logistic Regression	Có training, rẻ và giải thích được
ML semantic baseline	`cross-encoder/nli-distilroberta-base`	Pretrained NLI; cần kiểm chứng trên logs [M1]
Hybrid verifier	Deterministic rules + NLI + decision fusion	Phương pháp chính của RQ1
Fine-tuned NLI	Fine-tune cùng model nếu có dữ liệu đủ sạch	Mở rộng, không phải đường găng
LLM	Qwen3 1.7B quantized, thử 4B nếu đủ RAM	Tạo draft/repair; không bắt buộc fine-tune [M2]

Tách biệt rõ ML và LLM: ML/NLI dự đoán nhãn support của claim; LLM tạo câu và repair; BM25/RAG truy xuất dữ liệu; rule engine xác minh các ràng buộc xác định. Không gọi việc chạy LLM thuần prompt là huấn luyện ML.

4.4. Logic fusion và abstention

Thứ tự xử lý đề xuất:

1. Xác nhận claim thuộc incident; citation IDs hợp lệ và nằm trong ACL/scope.
2. Trích entities/attributes từ claim; kiểm tra field consistency và chronology.
3. Chạy NLI trên claim + representation của evidence; hỗ trợ tập nhiều events.
4. Áp dụng decision policy có trace: hard contradiction được ưu tiên nếu rule có độ chắc chắn cao; NLI không được ghi đè tùy ý.
5. Nếu evidence không đủ, score thấp hoặc rule/ML bất đồng → `Insufficient` hay `Needs Review` theo policy; không ép Supported.
6. Lưu `rule_hits`, `nli_scores`, `decision_reason`, `source_ids`, `model_version` để phân tích sai số.

Rule decision	NLI decision	Fusion đề xuất
Deterministic contradiction	Bất kỳ	Contradicted (kèm rule trace)
Pass các constraints	Entailment mạnh	Supported nếu đủ toàn bộ subclaims

Rule decision	NLI decision	Fusion đề xuất
No contradiction	Neutral/low confidence	Insufficient / Needs Review
Evidence thiếu	Bất kỳ	Insufficient
NLI ↔ rules bất đồng	Bất kỳ	Needs Review nếu không có hard constraint đáng tin

Nguy cơ nghiên cứu: rule viết quá khớp dataset có thể giúp in-domain nhưng gây OOD failure; phải chạy ablation tắt từng nhóm rule.

---

5. Evidence retrieval, summarization và omission checking

5.1. Retrieval

Bắt đầu với **structured filtering** (`incident_id`, time range, source, host) cộng **BM25**, chỉ bổ sung embedding retrieval (ví dụ MiniLM + FAISS) nếu Recall@k chưa đạt yêu cầu. Truy xuất phải giới hạn theo incident/tenant và giữ evidence ID ổn định. Đo `Recall@5`, `Recall@10`, `MRR` dựa trên gold supporting evidence, không chỉ đo độ tương đồng văn bản.

5.2. Structured summary

Output nên gồm `incident_overview`, `timeline`, `affected_entities`, `observed_behaviors`, `confirmed_outcomes`, `uncertainties`, `claims`, `citations`, `verification_status` và `analyst_notes`. Phân rã statement thành **atomic claims** trước verification. Các nhận định dự đoán hoặc kết luận nguyên nhân phải ghi rõ mức độ chắc chắn và được đối chiếu với evidence.

5.3. Critical-fact inventory

Mỗi incident có tập `gold_facts` (độc lập với summary generator), gồm: `initial_trigger`, `affected_entities`, `timeline`, `observed_behavior`, `confirmed_outcome`, `impact` (nếu chứng minh được), `uncertainty` và `limitations`. Mỗi fact có `criticality`, `evidence_ids`, `support_status`, `observability`, `annotation_source`.

Omission xảy ra khi một **critical supported fact** có trong gold inventory nhưng chưa được summary đề cập đúng hoặc tương đương ngữ nghĩa. Facts có mức `low` không bắt buộc xuất hiện. Không dùng output của chính LLM sinh summary làm nguồn duy nhất tạo gold facts, tránh evaluation circularity.

5.4. Controlled repair

Repairer nhận `unsupported_claims`, `uncovered_critical_facts` và evidence tương ứng. Hành động hợp lệ: **remove**, **qualify**, **rewrite with evidence**, **add verified missing fact**, **abstain**. Giới hạn tối đa 1–2 vòng và re-verify tất cả claims được sửa/thêm. Nếu không đủ support thì giữ cảnh báo, chuyển analyst review thay vì tự làm đầy báo cáo.

---

6. Dataset, annotation và tránh leakage

6.1. Nguồn dữ liệu

Nguồn	Giá trị	Điều cần lưu ý
OTRF Security-Datasets [D1]	Benign/malicious security event collections	Cần xây dựng incident boundaries và gold facts
Splunk Attack Data [D2]	Attack telemetry và scenario metadata	Cần chọn tập nhỏ; repository lớn, sử dụng Git LFS có chọn lọc
EVTX-ATTACK-SAMPLES [D3]	Windows/EVTX log samples theo TTP	Không mặc định là full incident narratives
Atomic Red Team + homelab [D4]	Controlled telemetry + ground truth	Synthetic và có nguy cơ khác biệt production SOC

Bộ **50 real-world incidents trong Kramer et al. không được mặc định là một public dataset tải sẵn**. Nhóm tự xây dựng evaluation protocol từ dữ liệu hợp lệ, tuân thủ license và không phát tán log chứa thông tin nhạy cảm.

6.2. Quy mô mục tiêu và phương án dự phòng

Mục tiêu mở rộng: 80 incident bundles: 40 train, 10 validation, 15 in-domain test, 15 OOD test. Nếu annotation không theo kịp: **minimum 50–60 incidents**, phải giữ một tập OOD test riêng và công bố rõ nghiên cứu mang tính feasibility.

- Mỗi incident dự kiến 5–10 gold critical facts và 5–15 candidate claims.
- Sinh có kiểm soát claim mutations/counterfactuals **chỉ trong train** để tăng dữ liệu supervision; mục tiêu 1.000–2.000 claim–evidence training pairs là **số mẫu tổng hợp**, không phải incident độc lập.
- Split theo **incident family, source collection, simulation run và environment**; không để các variants của cùng một original incident rơi vào train và test.
- Dữ liệu test phải human-reviewed. Không dùng LLM-generated labels làm gold standard chưa kiểm tra.

6.3. Minimal schemas

Incident bundle:

```
{
  "incident_id": "INC-001",
  "environment_id": "ENV-A",
  "source_dataset": "homelab",
  "scenario_family": "suspicious_authentication",
  "alert_ids": ["ALT-001"],
  "evidence_ids": ["E001", "E002", "E003"],
  "gold_facts": [
    {
      "fact_id": "F001",
      "statement": "A successful logon was recorded on WS01",
      "criticality": "high",
      "support_status": "supported",
      "evidence_ids": ["E003"],
      "annotation_source": "human_reviewed"
    }
  ]
}
```

Claim–evidence pair:

```
{
  "pair_id": "P001",
  "incident_id": "INC-001",
  "claim": "The administrator account was compromised",
  "evidence_ids": ["E003"],
  "claim_type": "inferred_outcome",
  "label": "insufficient",
  "annotation_source": "human_reviewed"
}
```

Event-level provenance: bắt buộc có `evidence_id`, `incident_id`, `source`, `timestamp_utc`, `normalized_fields`, `raw_message`, `sha256`, `acquisition_method`. Hash xác nhận dữ liệu snapshot không thay đổi, nhưng **không tự chứng minh log gốc đáng tin hoặc sự kiện có thật**.

6.4. Annotation protocol

1. Tạo định nghĩa ba nhãn S/C/I kèm ví dụ khó, phân biệt quan sát vs suy luận.
2. Xây dựng independent gold critical facts từ incident timelines, không dựa vào LLM draft.
3. Hai annotators độc lập chú giải ít nhất một phần test/OOD; ghi disagreement, adjudication và reason codes.
4. Báo cáo annotation agreement (ví dụ Cohen's kappa hoặc Gwet's AC1) cùng số lượng mẫu thực tế.
5. Kiểm toán theo `incident_id`, nguồn dữ liệu và template-family, bảo vệ test set khỏi leakage.
6. Đóng băng test labels và prompt/config trước final evaluation.

7. Đánh giá định lượng và thống kê

7.1. Primary metrics

Metric	Định nghĩa thực thi	RQ
Macro-F1	Trung bình F1 của Supported, Contradicted, Insufficient	RQ1, RQ3
Supported Precision	TP_supported / số mẫu model dự đoán Supported	RQ1, RQ3
False Support Rate	Gold C/I nhưng model kết luận S; báo cáo denominator rõ ràng	RQ1
Citation Validity	Tỷ lệ cited IDs tồn tại và thuộc incident/ scope	RQ1
Citation Support Accuracy (CSA)	Fully supported cited factual claims / tất cả cited factual claims	RQ1, RQ2
Unsupported Claim Rate (UCR)	Unsupported factual claims / tất cả factual claims trong summary	RQ1, RQ2
Critical Fact Recall (CFR)	Critical supported facts được đề cập đúng / tất cả gold critical supported facts	RQ2
Omission Rate	1 − CFR (với cùng fact eligibility/ denominator)	RQ2

Metric	Định nghĩa thực thi	RQ
OOD F1 Drop	Macro-F1(in-domain) − Macro-F1(out-of-domain)	RQ3

Định nghĩa được cố định trước: `unsupported` trong UCR gồm contradicted và insufficient; với summary ghi một cách trung thực về uncertainty, không coi câu "không đủ bằng chứng" là một factual error. Với citation support, một claim dẫn nhiều evidence chỉ đạt *fully supported* khi **tổ hợp** evidence thực sự hỗ trợ toàn bộ claim; không tính các citation thừa hoặc sai scope như bằng chứng đúng.

7.2. Secondary metrics

- **Retrieval:** Recall@5, Recall@10, MRR trên gold supporting event sets.
- **Robustness:** chênh lệch F1/UCR dưới IP/hostname substitution, schema remapping, timestamp normalization, benign noise và missing telemetry.
- **Latency:** p50/p95 overall và theo stage; báo cáo cold-start/warm-start, batch size, inference tokens.
- **Compute:** peak RSS, CPU/GPU hours, throughput, energy nếu đo được; không suy đoán GPU memory từ model file size.
- **Cost:** token consumption, API cost (nếu sử dụng), local compute proxy; tiền tệ và đơn giá ghi thời điểm đo.
- **Human-in-the-loop:** analyst review time, correction count, evidence-open actions, retained factual errors; nếu chỉ có proxy, phải gọi là proxy.

7.3. Statistical protocol

- So sánh các hệ thống **trên cùng incident/test split**, cùng retrieval output khi kiểm nghiệm verifier.
- Dùng paired bootstrap ở cấp **incident**, không lấy thousands of correlated claim pairs làm thousands of independent incidents.
- Trình bày confidence intervals 95%, effect sizes, per-environment metrics, confusion matrices và error taxonomy.
- RQ2 sử dụng **non-inferiority margin** đề xuất 3 điểm phần trăm UCR tuyệt đối, khóa trước test. Cần kiểm nghiệm giới hạn trên của confidence interval cho mức tăng UCR; "không có khác biệt có ý nghĩa" không đủ chứng minh không tăng lỗi.
- Nếu n nhỏ, mô tả exploratory/feasibility; không tuyên bố khả năng khái quát production SOC.

---

8. Thiết kế thí nghiệm (experiments và ablation)

8.1. Experiment E1 — RQ1: Evidence Verification

ID	Phương pháp	Mục đích
V0	Rule-only	Xem hiệu quả và giới hạn deterministic validation
V1	TF-IDF + Logistic Regression	Baseline supervised ML truyền thống
V2	Pretrained NLI-only	Baseline semantic verification
V3	Rules + **cùng** pretrained NLI	Main hybrid treatment
V4 (nếu đủ dữ liệu)	Fine-tuned NLI-only	Kiểm tra lợi ích domain adaptation
V5 (tùy chọn)	Rules + fine-tuned NLI	Kiểm tra khả năng cộng hưởng

Primary comparison: V3 vs V2, cùng evidence set, cùng model checkpoint và cùng policy thresholds đã khóa. Các ablations: bỏ entity rules, bỏ temporal rules, bỏ event semantic rules, bỏ abstention. Phân tích cụ thể false Supported và errors trên multi-evidence claims.

8.2. Experiment E2 — RQ2: Omission-aware Summarization

ID	Pipeline
S0	LLM-only (input incident context trong budget định trước)
S1	BM25/RAG + LLM + citations
S2	S1 + hybrid evidence verification, loại bỏ/sửa unsupported claims
S3	S2 + critical-fact omission checking + constrained repair + re-verification

Primary comparison: S3 vs S2 trên cùng incidents, LLM, prompt budget và evidence access. Báo cáo CFR, UCR, CSA, word/token count và latency. Tách tác động của retrieval, verifier và omission checking; không dùng S0 làm đối chứng duy nhất.

8.3. Experiment E3 — RQ3: Out-of-distribution Generalization

- **In-domain:** train/val và một holdout test từ Environment A, không trùng simulation run/template.
- **OOD:** Environment B có source collection/schema/telemetry setup khác, không xuất hiện trong training/tuning. Ghi rõ sự khác biệt thực chất giữa hai môi trường.
- **Counterfactual robustness:** R1 đổi IP/hostname (label-preserving); R2 đổi tên field/schema; R3 timestamp/timezone format; R4 thêm benign events; R5 loại bỏ từng phần telemetry; R6 thay đổi log-source mix.
- Với R5, **relabel theo evidence còn quan sát được** nếu support status thay đổi; không tiếp tục dùng gold label của evidence ban đầu.

So sánh **absolute OOD performance**, `ΔF1`, false-support/error rates theo loại shift và source family. Nếu chỉ đổi IP/hostname, gọi đúng là *perturbation robustness*, không gọi đó là cross-environment generalization đầy đủ.

8.4. Experiment E4 — Analyst Review và Efficiency (phụ)

Nếu có người tham gia: tổ chức within/between-subject balanced study trên các incident khác nhau nhưng tương đương độ khó; so sánh manual review với EGIS-SOC-assisted review. Tránh để cùng người thấy đáp án cùng incident trước khi sang điều kiện khác. Thu thập thời gian, số lỗi còn lại, số lần mở evidence, perceived usefulness; ghi số người và kinh nghiệm tham gia.

Nếu không tổ chức được user study: thay bằng `review-effort proxy` (số unsupported claims, số correction actions, số citation lookups). **Không diễn giải proxy thành giảm thời gian làm việc thực tế của analyst**.

9. Threat model và mitigations

9.1. Trust assumptions

- **Assets:** tính đúng của summary, evidence integrity/provenance, phân tách incidents, dữ liệu log nhạy cảm, analyst decisions.
- **Attack surface:** external CTI documents, user-controlled text in logs (URL, HTTP headers, command line, usernames), manipulated/suppressed telemetry, malicious citations.

- **Adversary goal:** đưa claim sai vào summary, xóa facts quan trọng, dẫn nguồn sai, làm rò rỉ dữ liệu hoặc gây quá tải inference.
- **Trust boundary:** retrieved logs/CTI là *untrusted data*, tuyệt đối không coi là system instructions; LLM không có quyền xóa log, mở mạng Internet tùy ý hoặc thực thi remediation.

9.2. Threat scenarios

Threat	Đường tấn công	Mitigation/validation
Hallucination	LLM khẳng định exfiltration khi chỉ có DNS queries	Claims + verifier + uncertainty status
Citation laundering	Citation ID có thật nhưng không chứng minh claim	Claim-level support check
Evidence mix-up	Dẫn log của host/incident khác	Incident-scoped retrieval, entity constraints
Omission	Bỏ successful logon hoặc lateral movement evidence	Independent critical-fact inventory
Indirect prompt injection	Raw log/CTI chứa instructions giả dạng	Delimit untrusted content, parser/ schema validation, output check
Data leakage	Query thiếu tenant/incident ACL	Read-only credentials, scoping, audit logs
Log tampering/absence	Log bị chỉnh sửa hoặc bị xóa	Hash/provenance, observable uncertainty, no overclaim
Distribution shift	Schema/log pattern lạ	Normalization, abstention, OOD tests
Denial of service	Long logs/context flood	Input caps, request timeout, concurrency limits

Security acceptance criteria: không retrieval chéo incident trong test suite; prompt-injection payload trong log không thể được coi là chỉ thị vận hành; không chấp nhận citation IDs giả; mỗi final claim có trạng thái đã kiểm chứng hoặc review warning. Đây là **mục tiêu test**, không phải bảo đảm tuyệt đối trước triển khai.

10. Tech stack, deployment và 4–12 GB RAM

10.1. Stack đề xuất

Layer	Technology	Lý do
Language + API	Python 3.11+, FastAPI, Pydantic	Dễ tích hợp SIEM và validate JSON
Processing	Pandas, JSONL/Parquet, SQLite	Dữ liệu có cấu trúc và provenance
Retrieval	Structured filters + BM25	Nhẹ, có baseline vững
Optional vectors	MiniLM embedding + FAISS	Chỉ bổ sung khi retrieval baseline thiếu
Baselines	Scikit-learn	Supervised ML với footprint thấp
Verification	NLI DistilRoBERTa, rules engine	So sánh ML-only/hybrid

Layer	Technology	Lý do
Summarization	Qwen3 1.7B/4B quantized	Local inference nhỏ [M2]
Inference runtime	llama.cpp / Ollama	Có tùy chọn chạy CPU và quantization
UI	Streamlit	Analyst review demo
Monitoring	Python structured logs; Prometheus optional	Audit latency/RAM/errors
SIEM connector	Splunk REST API (read-only)	Truy xuất event, mở lại nguồn gốc

10.2. Hardware target (phải đo thực tế)

RAM cấp cho EGIS-SOC	Triển khai khả thi để thử nghiệm	Ràng buộc
4 GB	BM25 + rules + Logistic Regression / NLI verifier; LLM ngoài VM	Không nên co-host LLM và toàn bộ pipeline
8 GB	Qwen3 1.7B quantized, retrieval và NLI **chạy tuần tự**	Context ngắn, 1 request một lúc, giám sát RSS
12 GB	Thử Qwen3 4B quantized cùng service gọn nhẹ	Kiểm tra peak RAM/KV cache; latency CPU có thể cao

Các mức trên là **design targets**, không phải phép đo benchmark hay bảo đảm tương thích. File model chỉ là một phần tổng bộ nhớ inference. Đặt protocol đo máy, CPU, OS, context length, quantization, batch/concurrency, cold/warm cache trước khi công bố benchmark.

10.3. Mapping sang SOC homelab

```
Windows/Sysmon + OPNsense + IDS/IPS
                |
                v
     Existing Splunk SIEM
     alerts + incident scope
                |
          read-only API
                v
    EGIS-SOC (lightweight service)
     retrieval | verification | UI
                |
      local LAN / Tailscale
                v
     Laptop 32 GB RAM (LLM)
                |
                v
      Analyst review / report
```

Khuyến nghị tài nguyên: vì Proxmox host 16 GB RAM đang chạy homelab, không cấp mặc định một VM EGIS-SOC 12 GB; ưu tiên VM/container nhỏ cho verifier, dùng laptop 32 GB chạy LLM. Khi thử standalone 8–12 GB phải tắt bớt workload hoặc dùng máy riêng. Không cần Shuffle/SOAR ở phiên bản đầu.

10.4. Operational safeguards

Service dùng API key Splunk read-only, allowlist indexes/search patterns, query timeout, limit events/context, TLS/Tailscale cho kết nối, local encrypted storage nếu có log nhạy cảm, log audit của analyst decisions và retention policy. Raw evidence cần được lưu hoặc liên kết đến source theo quyền truy cập, không phát tán log nhạy cảm trong repository.

11. Lộ trình triển khai chi tiết 8 tuần

Tuần / ngày	Công việc chính	Deliverables / tiêu chí nghiệm thu
W1 · 12–18/10	Literature matrix; research gap; RQ/ hypothesis; schema; annotation guideline; threat model; xác định datasets và licenses	`research-protocol.md`, architecture v1, split policy và danh sách baseline
W2 · 19–25/10	Ingest/normalize; incident bundling; evidence hashing; 10–15 pilot incidents; gold facts, S/C/I labels; hard-negative generator chỉ train	Pilot dataset, parser tests, annotation v1, sample quality review
W3 · 26/10–01/11	Structured/BM25 retrieval; TF-IDF+LR baseline; pretrained NLI; Recall@k, F1 pilot; log tracking	Retrieval API + V1/V2 benchmark script và report v1
W4 · 02–08/11	Entity/temporal/event rules; fusion/ abstention; V0–V3; error analysis; khóa RQ1 protocol	Hybrid verifier v1, RQ1 pilot, unit tests cho rules
W5 · 09–15/11	Qwen3 structured generation; atomic claim extraction; citation rendering; critical-fact matching; constrained repair; S0–S3	End-to-end summarizer và RQ2 pilot, analyst review UI tối thiểu
W6 · 16–22/11	Held-out Environment B; OOD evaluation; perturbations R1–R6; RAM/ latency/tokens; robustness errors	RQ3 report, robustness/efficiency tables và system profiling
W7 · 23–29/11	Full baseline/ablation; annotation agreement; paired bootstrap; human study nếu khả thi; plot, split audit	Frozen tables/figures, reproducible test runs, known limitations
W8 · 30/11–06/12	Paper/report, packaging, Streamlit demo, README, model cards, final acceptance tests	Final report/paper draft, public-safe repo, demo từ Splunk, reproducibility checklist

11.1. Milestones bắt buộc

- **M1 – 25/10:** Có ≥10 incident pilot hoàn chỉnh, parser/schema/annotation có test.
- **M2 – 08/11:** V3 hybrid có thể đo trên cùng tập test với V2 NLI-only; có phân tích lỗi.
- **M3 – 22/11:** Full pipeline chạy từ incident evidence → summary → verification/repair; có OOD split thực sự độc lập.
- **M4 – 06/12:** Hoàn tất đủ RQ1–RQ3, ablation, efficiency, báo cáo limitations và GitHub demo.

Lịch phụ thuộc: không chờ xây xong 80 incidents mới code; khởi động bằng 10–15 pilot incidents. Dataset annotation, hệ thống và metric scripts được phát triển song song từ W2 đến W6.

11.2. Phân chia công việc tham khảo (nhóm 2 người)

Workstream	Thành viên A	Thành viên B	Cùng thực hiện
Dataset	Ingestion, Splunk connector	Gold fact schema, annotation tooling	Audit, split/leakage checks

Workstream	Thành viên A	Thành viên B	Cùng thực hiện
Models	NLI baselines, hybrid fusion	RAG, generation, omission checker	Experiments và error analysis
Evaluation	RQ1, RQ3 scripts	RQ2, latency/UX scripts	Gold test review, confidence intervals
Deliverable	Service/API/reproducibility	Dashboard/report writing	Paper revision, final demo

12. Rủi ro tiến độ và chiến lược tối thiểu (MVP)

Rủi ro	Dấu hiệu	Hành động giảm thiểu
Annotation chậm	<10 incident sạch đến cuối W2	Giữ minimum 50 incidents; giảm số templates, không giảm chất lượng test
NLI không hiểu log	False-support cao ở semantic events	Structured verbalization, error taxonomy; thử fine-tune sau baseline
LLM quá chậm trên VM	p95 và peak RSS quá cao	Chạy LLM trên laptop, model nhỏ hơn, batch tuần tự
Retrieval yếu	Recall@10 thấp trên gold evidence	Nâng structured search trước khi thêm vectors
OOD không độc lập	B chỉ là đổi tên A	Lấy collection hoặc telemetry pipeline độc lập
Repair tạo thêm hallucination	S3 tăng CFR nhưng UCR cũng tăng	Chỉ add supported facts; re-verification; giới hạn 1–2 vòng
Time overruns	W5 chưa có end-to-end	Bỏ fine-tuning, vectors, multi-agent và SOAR; giữ 3 RQ

Ưu tiên P0: dataset được kiểm toán, ML-only/hybrid comparison, RAG + summary + citations, omission checking, in-domain/OOD results. **P1:** latency/RAM/cost, perturbation stress tests, analyst study. **P2 (có thể bỏ):** fine-tuning NLI, FAISS vectors, multi-agent, SOAR integration.

13. Repository structure và reproducibility

```
egis-soc/
├── configs/
│   ├── models.yaml
│   └── experiments.yaml
├── data/
│   ├── raw/              # private / gitignored
│   ├── normalized/
│   ├── annotations/
│   └── splits/
├── src/
│   ├── ingestion/
│   ├── retrieval/
│   ├── models/
│   ├── verification/       # rules.py, nli.py, fusion.py
```

```
│   ├── summarization/
│   ├── omission/
│   └── evaluation/
├── experiments/
│   ├── rq1_verification.py
│   ├── rq2_omission.py
│   ├── rq3_generalization.py
│   └── ablation.py
├── api/
├── dashboard/
├── tests/
├── docs/
│   ├── research-protocol.md
│   ├── annotation-guidelines.md
│   ├── threat-model.md
│   └── limitations.md
├── paper/
├── README.md
└── requirements.txt
```

Reproducibility checklist: cố định seed/split, công bố exact model revision, prompt version, quantization, machine specs, eval scripts, per-incident results (ẩn dữ liệu nhạy cảm), gold annotation policy và mọi loại missing data. Đánh giá trên test set đóng băng. README cần hướng dẫn demo không dùng real credentials.

---

14. Acceptance criteria và sản phẩm bàn giao

14.1. Acceptance criteria (không giả định kết quả nghiên cứu phải dương)

- ☐ Có incident bundle hợp lệ, mỗi evidence ID truy xuất được source và raw event/provenance.
- ☐ Có baseline ML, pretrained NLI, hybrid và cùng gold claim–evidence split; chạy được Macro-F1 và confusion matrix.
- ☐ Có report S0–S3 và bộ `gold_facts` độc lập; tính được CFR, UCR, CSA.
- ☐ Có OOD test từ nguồn độc lập và ít nhất một perturbation suite; report per-environment errors.
- ☐ Có kết quả latency p50/p95, peak memory và token/cost report theo cấu hình máy được mô tả.
- ☐ Có ít nhất một demo chạy từ Splunk alert/evidence đến analyst review.
- ☐ Có threat-model tests và documented limitations.
- ☐ Có scripts tái lập cùng mô tả dataset/annotations và không lộ thông tin nhạy cảm.

14.2. Final deliverables

1. Source code, requirements, model/config versions và unit/integration tests.
2. Dataset protocol, schemas, annotations cho các split, source provenance.
3. Experiment tables/figures, ablation, confusion matrices, paired uncertainty estimates.
4. FastAPI service, Streamlit analyst review UI và Splunk integration demo.
5. Final academic report/paper draft có method, RQs, threat model, results, limitations, reproducibility statement.

14.3. Kết quả kỳ vọng theo hai cấp độ

- **Môn học:** hệ thống hoạt động, pipeline có thể kiểm thử, bộ dữ liệu có gold labels, benchmark định lượng cho 3 RQ và demo.
- **Paper potential:** tính mới phải được chứng minh qua kết quả đối chứng và error analysis; 50–80 incidents thường thích hợp để bắt đầu **feasibility study**, không đủ để khẳng định tổng quát hóa production SOC trên diện rộng. Nếu thí nghiệm không cải thiện baseline, vẫn cần báo cáo trung thực và tìm hiểu điều kiện thất bại.

15. Tài liệu tham khảo và tài nguyên triển khai

> **Lưu ý hiệu đính.** Bài survey *AI-Augmented SOC: A Survey of LLMs and Agents for Security Automation* (2025) được xuất bản bởi **Srinivas và cộng sự**, trên *Journal of Cybersecurity and Privacy*, **không phải "Mishra et al., Computers"**. Các mục dưới đây được ưu tiên theo trang publisher hoặc repository chính thức (đối chiếu 09/10/2026). Các con số trong phần bối cảnh, nếu có, là con số nghiên cứu nguồn.

15.1. Literature

- **[R1]** Kramer, D., et al. (2025). *Integrating Large Language Models into Security Incident Response.* SOUPS 2025, USENIX. https://www.usenix.org/conference/soups2025/presentation/kramer
- **[R2]** Srinivas, S., et al. (2025). *AI-Augmented SOC: A Survey of LLMs and Agents for Security Automation. Journal of Cybersecurity and Privacy*, 5(4), 95. DOI: 10.3390/jcp5040095. https://www.mdpi.com/2624-800X/5/4/95
- **[R3]** *Cognitive SOC: Evidence-Backed Narrative Generation for Security Operations with Multi-Agent LLM Architecture.* IEEE BigData 2025; IEEE Xplore 06/03/2026. DOI: 10.1109/BigData66926.2025.11401968. https://ieeexplore.ieee.org/document/11401968/
- **[R4]** Zhang, H., et al. (2026). *From Ambiguous Queries to Verifiable Insights: A Task-Driven Framework for LLM-Powered SOC Analysis. CAAI Transactions on Intelligence Technology*. DOI: 10.1049/cit2.70138. https://ietresearch.onlinelibrary.wiley.com/doi/10.1049/cit2.70138
- **[R5]** Cadet, X., et al. (2026). *Retrieval-Augmented LLMs for Security Incident Analysis.* ACM Conference on AI and Agentic Systems 2026. DOI: 10.1145/3786335.3813136. https://doi.org/10.1145/3786335.3813136
- **[R6]** Yue, X., et al. (2023). *Automatic Evaluation of Attribution by Large Language Models.* Findings of EMNLP 2023, pp. 4615–4635. DOI: 10.18653/v1/2023.findings-emnlp.307. https://aclanthology.org/2023.findings-emnlp.307/

15.2. Datasets, models và kỹ thuật

- **[D1]** OTRF Security-Datasets: https://github.com/OTRF/Security-Datasets
- **[D2]** Splunk Attack Data: https://github.com/splunk/attack_data
- **[D3]** EVTX-ATTACK-SAMPLES: https://github.com/sbousseaden/EVTX-ATTACK-SAMPLES
- **[D4]** Atomic Red Team: https://github.com/redcanaryco/atomic-red-team
- **[M1]** `cross-encoder/nli-distilroberta-base` model card: https://huggingface.co/cross-encoder/nli-distilroberta-base
- **[M2]** Qwen3 model family in Ollama: https://ollama.com/library/qwen3
- **[S1]** OWASP Top 10 for LLM Applications (prompt injection and related risks): https://genai.owasp.org/llm-top-10/